exec.pyc

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 14s >

Este arquivo é malware (malicioso).

Análise passo a passo

1. **Tipo de arquivo**
   É um arquivo `.pyc` (bytecode Python compilado) para **Python 3.12** (magic number `f30d0d0a`). O cabeçalho e a estrutura confirmam que é um módulo Python compilado, não um arquivo legítimo simples.
2. **Estrutura e constantes extraídas**
   O código principal (`<module>`) define constantes e funções com nomes altamente suspeitos:
   - Diretórios ocultos: `/root/.s/` , `/root/.a/` , `/opt/monitor`
   - Serviços systemd persistentes: `scan-runner.service` e `file-monitor.service`
   - Credenciais hardcoded:
     - Senha: `LeitboGi0ro,123@@@`
     - Token do Telegram Bot: `7431501378:AAHTIaWSQ1Gcqp5ovhY6-6L1TG8Npubq1Ug`
     - Chat ID: `743493786`
     - Identificador: `[☢全部3☢]`
   - Scripts embutidos (como strings grandes) para:
     - Scanner SSH com **paramiko** (força bruta / autenticação em massa)
     - Uso de **masscan** (scanner de portas em alta velocidade)
     - Filtros de IPs, extração de IP:porta
     - Script bash `run_scan.sh` que orquestra masscan + scanners SSH em sessões `screen`
3. **Funcionalidades maliciosas identificadas**
   - **Varredura ofensiva**: masscan nas portas 22 e 5522 + tentativas de login SSH com senhas conhecidas.
   - **Propagação / worm**: lê arquivos de resultados (`LeitboGi0ro.txt` , `q123.txt`), conecta via SSH em hosts vulneráveis, envia um payload (`bendi.py`) e o executa remotamente.
   - **Persistência**: cria e ativa serviços systemd que rodam como root, com `Restart=always` .
   - **C2 (Command & Control)**: envia rela
     também se comunica com APIs centrais (`https://sou.pp.ua` ,

Copied link to clipboard. Shared links can be viewed by anyone with the link.

`https://sexy.pp.ua`).

- **Instalação de agente adicional**: após comprometer um host, instala um agente de monitoramento (`komari-agent`) a partir de um repositório GitHub.
- **Auto-limpeza**: o próprio script tenta se apagar após o deploy bem-sucedido.
- Ambiente virtual isolado (`venv`) com instalação de `paramiko` e `tqdm` .

4. **Comportamento típico de malware**
   - Criação de pastas ocultas em `/root` .
   - Uso de `screen` para processos em background.
   - Coordenação central via API para evitar retrabalho (check/add IP).
   - Relatórios em Markdown para o Telegram com status de cada etapa (sucesso/falha na propagação, instalação de agente, etc.).
   - Foco em servidores Linux (VPS) com senhas fracas ou reutilizadas.

Conclusão

O arquivo **não é benigno**. Trata-se de um **malware de varredura e propagação SSH** (tipo botnet/worm) projetado para:

- Escanear a internet em busca de servidores SSH vulneráveis,
- Comprometer hosts com senhas conhecidas,
- Instalar persistência e agentes de monitoramento,
- Reportar resultados via Telegram e APIs próprias,
- Continuar a se espalhar automaticamente.

Recomendação: Não execute este arquivo em nenhum ambiente. Se ele já rodou em algum sistema, isole a máquina imediatamente, verifique os serviços systemd mencionados, pastas `/root/.s/` , `/root/.a/` e `/opt/monitor` , e rotacione todas as credenciais envolvidas.

Qual é a categoria principal deste malware?

Worked for 1s >

Categoria principal: Worm (verme de rede) / SSH Worm

Mais especificamente, trata-se de um **SSH Worm** (verme de propagação via SSH), com características secundárias de botnet.

Justificativa da classificação:

Característica observada	Categoria correspondente
Varredura ativa de IPs (masscan nas portas 22/552	
Tentativa de login com senhas conhecidas/fracas	

Copied link to clipboard. Shared links can be viewed by anyone with the link.

Característica observada	Categoria correspondente
Upload + execução automática de payload nos hosts comprometidos	**Propagação autônoma**
Criação de serviços systemd persistentes	Persistência
Relatórios para Telegram + API central	C2 (Command & Control)
Continuação automática do ciclo em novos hosts	**Comportamento de worm**

O elemento definidor é a **capacidade de se auto-propagar** de forma autônoma pela rede, explorando credenciais fracas em serviços SSH. Isso o classifica prioritariamente como **Worm**, e não apenas como um simples bot, trojan ou scanner.

Classificações secundárias possíveis:

- Botnet (devido ao C2 via Telegram e coordenação central)
- Credential-based malware / SSH brute-forcer

A categoria **principal** permanece **Worm (SSH Worm)**.

↘ Como ele se espalha pela rede

↘ Quais são os indicadores de comprometimento do worm

↘ Quais são as características secundárias

Copied link to clipboard. Shared links can be viewed by anyone with the link.